CONTROLS AND COMPLIANCE CHECKLIST

INTERNAL SECURITY AUDIT · BOTIUM TOYS

AUDITOR	ROLE	RISK SCORE	REFERENCE
Kelly Guzman	**Founder & SOC Analyst, CTA**	**8 / 10 (High)**	**Google CC · Course 2**

Audit overview

Scope: The entire security program at Botium Toys, including employee equipment and devices, internal network, and systems.

Goals: Assess existing assets and complete controls and compliance checklists to determine which controls and best practices need implementation to improve Botium Toys' security posture.

Risk Score: 8 out of 10 (High). Due to a lack of controls and insufficient adherence to compliance best practices.

Controls assessment checklist

Does Botium Toys currently have this control in place?

YES	NO	CONTROL
	X	Least Privilege
	X	Disaster recovery plans
X		Password policies
	X	Separation of duties
X		Firewall

	X	Intrusion detection system (IDS)
	X	Backups
X		Antivirus software
	X	Manual monitoring, maintenance, and intervention for legacy systems
	X	Encryption
	X	Password management system
X		Locks (offices, storefront, warehouse)
X		Closed-circuit television (CCTV) surveillance
X		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

YES	NO	BEST PRACTICE
	X	Only authorized users have access to customers' credit card information.
	X	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	X	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
X		Adopt secure password management policies.

General Data Protection Regulation (GDPR)

YES	NO	BEST PRACTICE
X		E.U. customers' data is kept private/secured.

	X	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	X	Ensure data is properly classified and inventoried.
X		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

YES	NO	BEST PRACTICE
	X	User access policies are established.
	X	Sensitive data (PII/SPII) is confidential/private.
	X	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
X		Data is available to individuals authorized to access it.

Recommendations

Based on this audit, the following actions are recommended to reduce risk and improve Botium Toys' security posture. Items are prioritized by risk severity:

1. Implement least privilege and separation of duties immediately to restrict access to cardholder data and PII/SPII. Currently, all employees have access to internally stored data, which is a critical compliance failure under PCI DSS and SOC standards.
2. Deploy encryption for customer credit card data in transit and at rest. This is required for PCI DSS compliance and directly addresses the current exposure of payment information.
3. Establish disaster recovery plans and implement regular backups of critical data. Without these, a single incident could result in total loss of business continuity.
4. Install an intrusion detection system (IDS) to provide network monitoring and threat detection capabilities that are currently absent.
5. Strengthen password policies to meet current minimum complexity requirements and deploy a centralized password management system to enforce those policies consistently.
6. Establish a regular schedule for legacy system monitoring, maintenance, and intervention with clearly documented procedures.

7. Classify and inventory all assets, including data, to meet GDPR and NIST CSF Identify function requirements.